信息安全综合实验课程实验报告

实验四：使用 BurpSuite 对 HTTPS 流量进行中间人篡改

学　　院　密码与网络空间安全学院

专　　业　信息安全、法学双学位班

学　　号　2313815

姓　　名　段俊宇

班　　级　信息安全、法学双学位班

一、实验目的

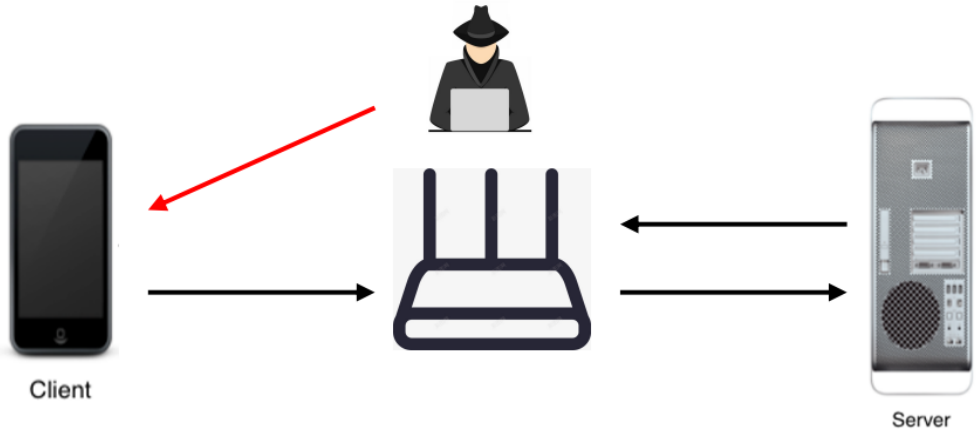
1. 初步了解 Burp Suite 的使用方式
2. 掌握中间人攻击原理、TLS 保护的通信过程以及对 HTTPS 实现中间人攻击的具体流程
3. 在实践中加深对于中间人流量劫持和 HTTPS 原理的理解

二、实验原理

2.1 中间人攻击

中间人攻击（Man-in-the-Middle Attack，简称 MITM 攻击）是一种常见的网络攻击手段，攻击者通过在网络通信的双方之间插入自己，截获、篡改或伪造双方的通信内容，从而实现窃取敏感信息、篡改数据或破坏通信的目的。

中间人攻击的基本原理是黑客通过某种手段，如 ARP 欺骗、DNS 劫持、Wi-Fi 劫持等方式，让通信双方误以为与对方直接通信，而实际上所有的通信都经过黑客控制的中间环节。在这个过程中，黑客可以窃取双方的敏感信息，如账号密码、信用卡信息等，也可以篡改通信内容，导致双方交互的结果出现问题。



2.2 TLS 保护的通信过程

TLS（传输层安全协议）保护的通信过程是一种加密通信方式，旨在确保数据在传输过程中的安全性和完整性。TLS 保护通信的主要步骤为：

1. **握手阶段**

握手阶段是 TLS 协议的核心部分，用于协商加密参数并建立安全连接。具体步骤如下：

- 客户端发起请求（Client Hello）：客户端向服务器发送“Client Hello”消息，包含支持的 TLS 版本、加密算法列表和一个随机数（Client Random）。
- 服务器响应（Server Hello）：服务器选择双方都支持的 TLS 版本和加密算法，生成一个随机数（Server Random），并发送“Server Hello”消息。
- 服务器证书发送：服务器向客户端发送其数字证书，证书中包含服务器的公钥和身份信息。
- 客户端验证证书：客户端使用本地存储的证书颁发机构（CA）根证书验证服务器证书的有效性，确保服务器身份合法。
- 密钥交换：客户端生成一个预主密钥（Pre-Master Secret），用服务器的公钥加密后发送给服务器。服务器使用私钥解密，得到预主密钥。
- 生成会话密钥：客户端和服务器使用预主密钥和随机数生成对称加密的会话密钥，用于后续数据加密。
- 握手完成：双方交换“握手完成”消息，握手成功。

2. **数据传输阶段**

握手完成后，客户端和服务器使用对称加密算法（如 AES）对数据进行加密和解密，并通过消息认证码（MAC）验证数据完整性。

3. **连接关闭阶段**

通信结束后，双方通过发送特定的关闭消息安全地关闭连接。

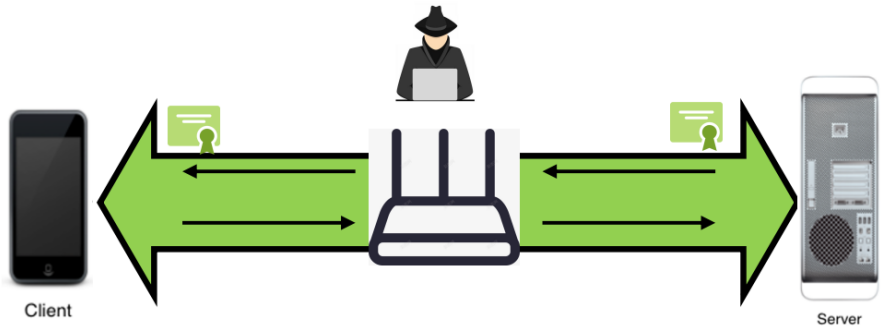


图 2 TLS 保护的通信过程

2.3 对 HTTPS 的中间人攻击

HTTPS 的安全性依赖于数字证书和证书链的验证机制。客户端（如浏览器或应用程序）在建立 HTTPS 连接时，会执行以下验证步骤：首先，客户端会验证服务器证书是否由一个可信的证书颁发机构（CA）签发；然后，客户端会检查证书链的最顶层（根 CA 证书）是否存在于客户端的“受信任的根证书存储”中；之后，客户端会验证证书中的域名是否与目标服务器的域名一致；最后，客户端会检查证书是否过期或被吊销。如果客户端信任了一个伪造的根证书，那么所有由该伪造根证书签发的证书都会被视为“可信”，从而绕过证书验证机制。

如果攻击者能够控制客户端设备安装恶意根证书，一旦客户端信任了伪造的根证书，攻击者就可以实施中间人攻击：

1. **客户端发起 HTTPS 请求：**客户端尝试访问目标服务器。
2. **攻击者拦截请求：**攻击者在网络中拦截客户端的请求，并向客户端提供伪造的服务器证书。
3. **客户端验证证书：**证书由伪造的根证书签发，而伪造的根证书已被安装到客户端的受信任根证书存储中。因此，客户端会认为证书是可信的。
4. **建立加密通信：**客户端与攻击者之间建立加密通信，攻击者使用伪造证书的私钥解密客户端的请求。攻击者再将请求转发到真实的目标服务器，并获取响应。
5. **数据篡改与转发：**攻击者可以解密客户端和服务器之间的通信，窃取敏感信息或篡改数据。攻击者将篡改后的数据重新加密并发送给客户端。

攻击成功的关键在于客户端信任了伪造的根证书。只要客户端信任了伪造的根证书，攻击者就可以生成任意伪造的服务器证书，从而绕过 HTTPS 的安全机制。

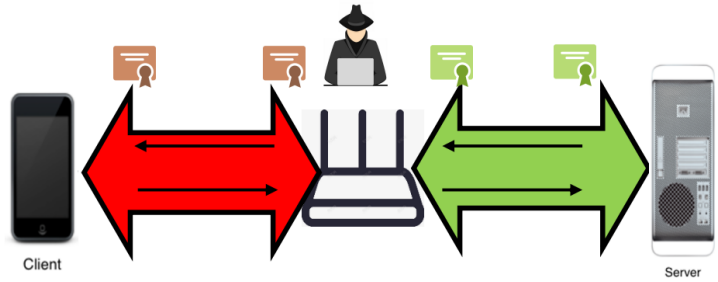
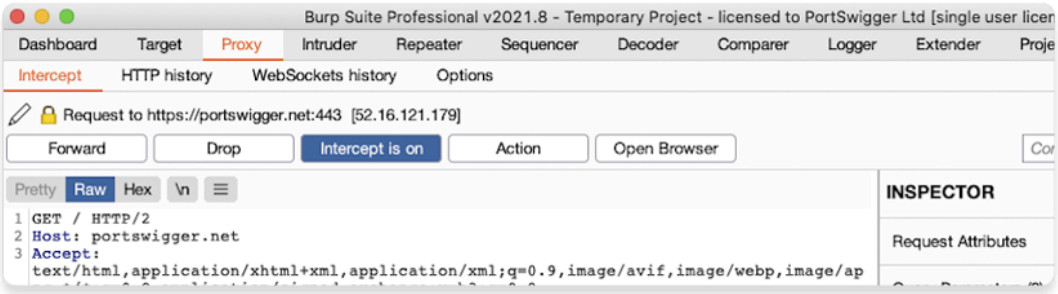


图 3 对 HTTPS 的中间人攻击原理

2.4 Burp Suite 介绍

Burp Suite 是一款功能强大的 Web 渗透测试工具，包含支持 HTTPS 的代理功能，具有友好的图形化界面定制，可以发送 Web 数据。



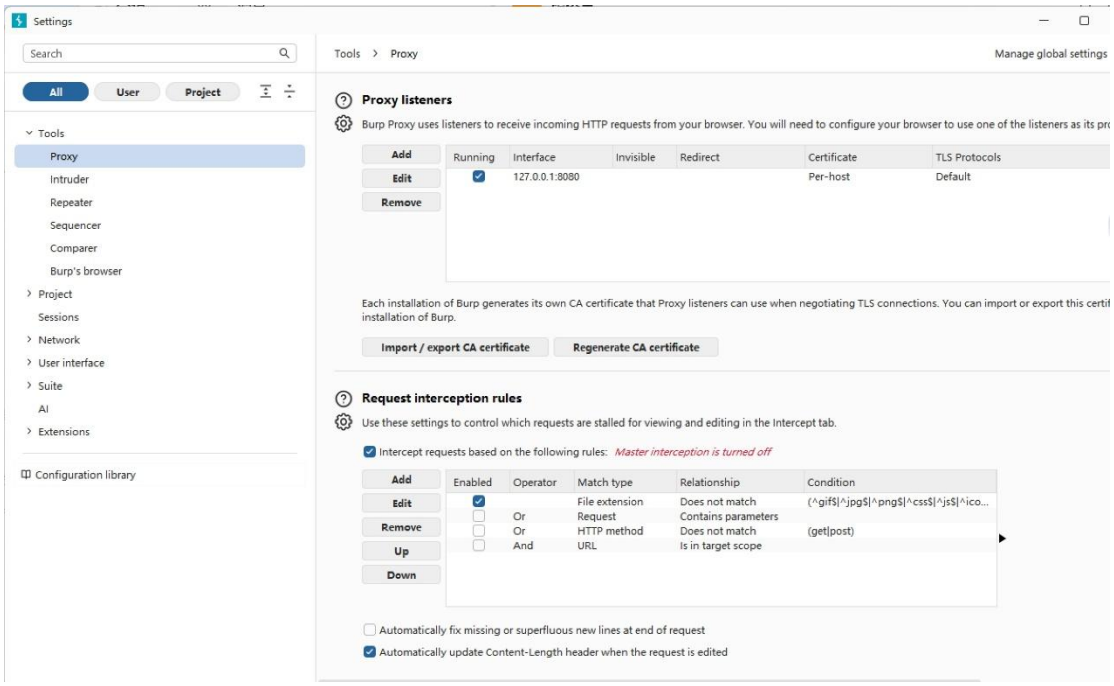
三、实验环境

Windows11 操作系统 + BurpSuite

四、实验过程

1. 证书安装和热点连接

首先打开 BurpSuite->Proxy，然后进入设置，将当前监听的 127.0.0.1 证书导出，并发送到手机上。

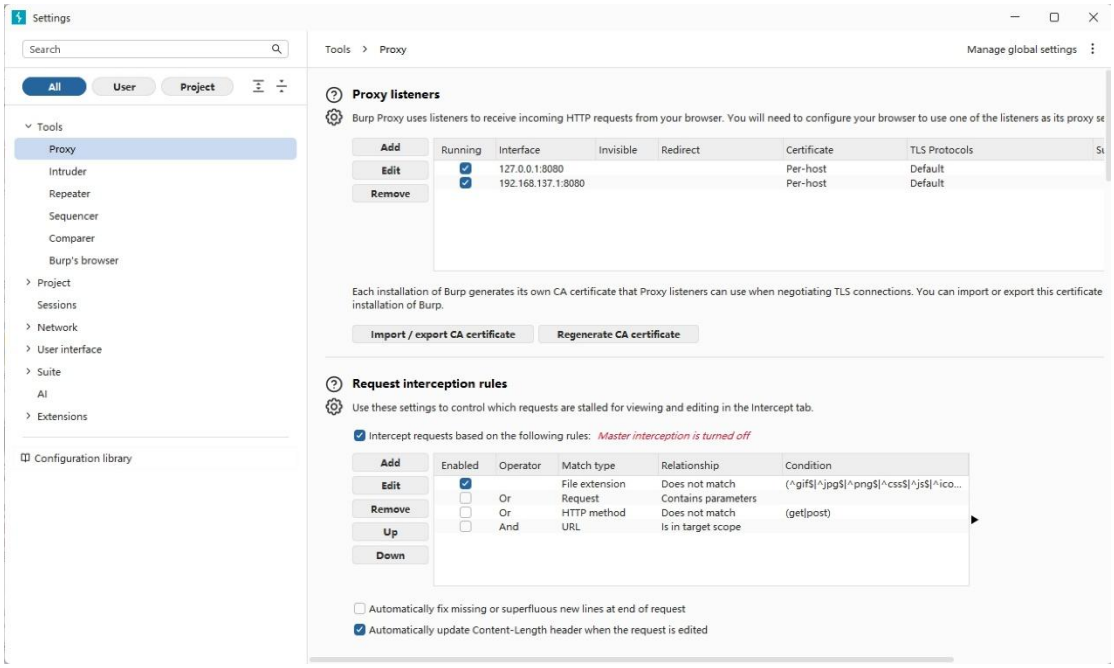


接下来需要开启手机的开发者模式，在网上搜索后发现在关于手机页面点击 HarmonyOS 版本号 7 次即可开启。然后需要在安全->更多安全

设置->加密和凭据中选择从存储中安装，之后在受信任的凭据->用户中查看，发现有新的证书，这个就是刚刚安装的证书。

下面需要打开电脑热点并连接，之后在连接的 wifi 中将代理设置为手动，服务器主机名设置为 192.168.137.1，端口为 8080。

在 BurpSuite 代理设置的监听中添加这条记录，这样就可以监控手机的流量。



2. 拦截网页并篡改内容

（1） 拦截请求内容

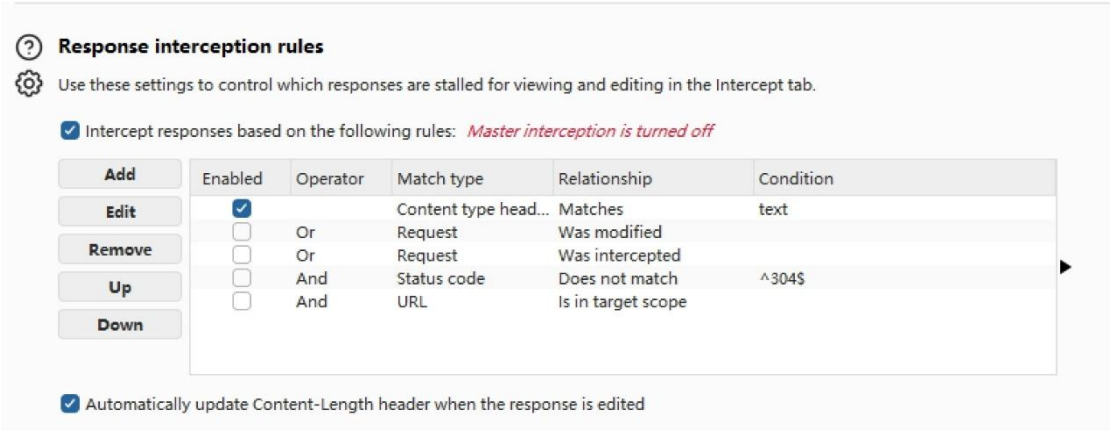
打开手机的系统浏览器并输入 hello，在 BurpSuite 中开始监听，手机搜索 hello 后发现处于加载界面，而 BurpSuite 成功拦截到了请求的内容。

之后点击 forward 也就是放行数据包，发现拦截到了手机的具体型号内容。

再次点击放行，手机浏览器可以加载出正常的搜索结果，说明拦截网页内容成功。

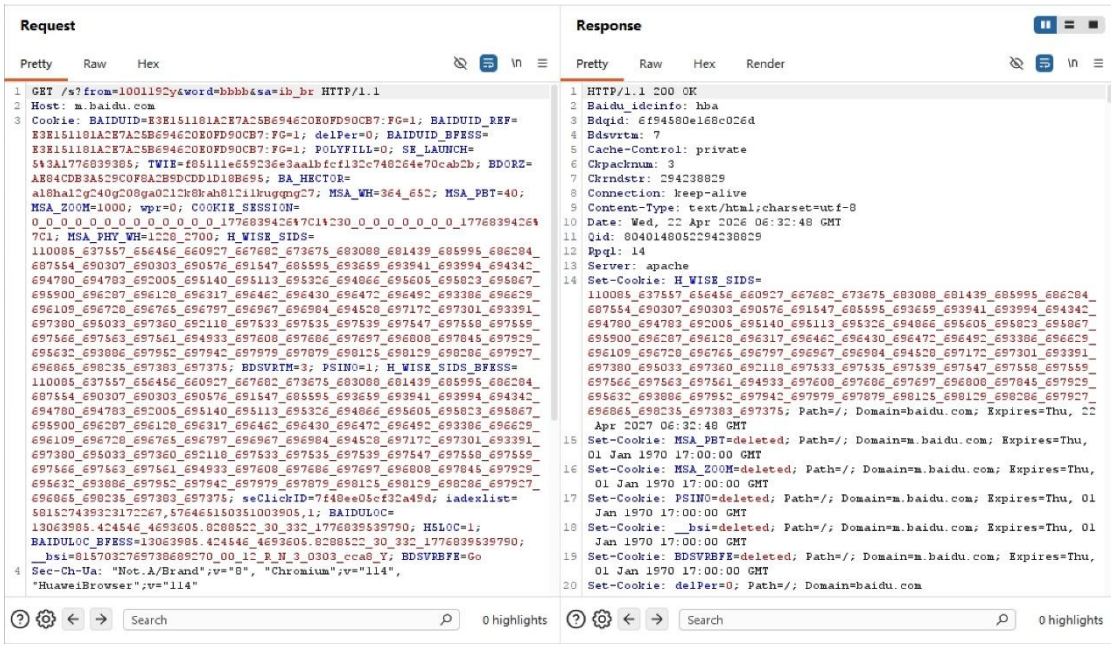
（2） 篡改请求内容

接下来在代理设置中勾选对 response 的监听，这样可以拦截请求的结果。



然后重复上述过程，在拦截到请求内容后修改 hello 为 bbbb。

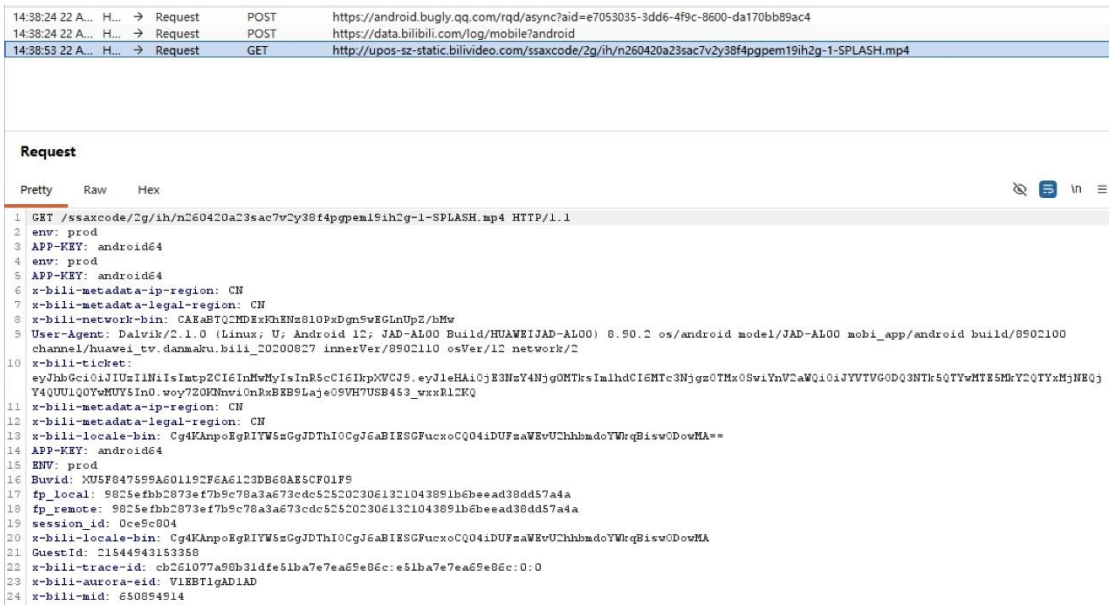
然后点击放行，会发现拦截到搜索结果，此时手机上仍然在加载。



点击放行会将搜索结果返回到手机浏览器，这是我们发现搜索框显示的是 hello，但实际返回的是 bbbb 的搜索结果，这样就完成了中间人攻击，即对流量进行拦截篡改。

3. 拦截除浏览器外的任一 APP 的流量

接下来我对 bilibili 进行了尝试，打开并点击任一视频，发现在 BurpSuite 上成功拦截到流量，这样就完成了本次实验！



五、实验结论及心得体会

本次实验通过手机连接电脑热点并安装证书，成功使用 BurpSuite 拦截到手机浏览器请求的内容，并实现了中间人攻击，对内容进行了篡改。此外，使用除浏览器外的 APP 也会被监听到，这表明一旦客户端信任了伪造的根证书，就可能会遭到攻击者对流量的拦截和篡改，造成隐私的泄漏。这次实验让我深刻认识到证书在 HTTPS 通信中的重要性，提升了安全意识。